Northstar Health

Management Letter (Internal ISO/IEC 27001:2022 Audit)

Audit period: 13 to 21 July 2026
Addressed to: Executive Leadership, Northstar Health

Purpose of this Letter

This letter pulls out what leadership actually needs to see from the internal audit. For the full picture, including every finding and the evidence behind it, see the internal audit report and the nonconformity register.

Headline Result

We ran eighteen tests across the twelve controls in scope. Every single one turned up a nonconformity. Three are major and need priority attention and fifteen are minor.

What's worth flagging up front is that two of the three major findings aren't new. They were raised in last year's audit and reported to us as closed, however, they're not.

Priority Items for Leadership Decision

Privileged account MFA (A.8.5, recurrence of NC-25-01)
Two active accounts with access to privileged functions are still logging in with password + and SMS, even though their MFA exception expired months ago. This is the exact same gap flagged last year and marked closed.
What we need: confirm whether these accounts fall under the privileged-MFA policy.

Backup restore testing (A.5.30 / A.8.13, recurrence of NC-25-02)
Nobody has tested a restore since the 2025 database migration. The only restore evidence on file is from August 2024, against a database version that isn't even in production anymore. A backup completing successfully doesn't tell us the data can actually be restored.
What we need: authorize and schedule a restore test against the current production database.

Supplier security assessment (A.5.19, HelpSphere)
HelpSphere has had access to patient-support attachments since May 2026, and there's still no completed security assessment or approved risk decision on file. A privacy questionnaire was used in place of the actual security review.
What we need: a valid decision on whether HelpSphere's access should continue while this is pending, and a target date for getting the real assessment done.

Where This Audit Differs From Management's View

During interviews, we were given two reasons why the first two items above should already be considered resolved. We didn't find either one sufficient to close the findings, and we want leadership to weigh in directly rather than have this get quietly resolved one way or the other.

"The MFA exclusions are emergency accounts and don't count."
These accounts can still reach privileged functions. What's not clear from the evidence is whether they're actually meant to fall inside the privileged-MFA control's scope. Nothing on file shows the exception was renewed, or that these accounts were ever formally carved out of the control. So this stays an open disagreement, not a resolved one.

"A green backup job is our restore test."
A successful backup tells us the data got written somewhere. It doesn't tell us if it can be pulled back out, and it definitely doesn't tell us the restore process works against what's actually running in production now. The only restore evidence we have predates the 2025 migration entirely.

Minor Findings

Fifteen more minor nonconformities came up, spanning:

- access review completeness
- identity lifecycle timing
- awareness and role-specific training
- incident evidence labeling
- vulnerability SLA adherence
- change approval timing and segregation of duties
- log coverage and retention
- supplier security review procedure

Full detail, ownership, and evidence locators for each are in nonconformity-register.csv.

Audit Limitation

There's a limitation affecting sample documentation and sample sizing. It's explained fully in the internal audit report and sample manifest. It doesn't undercut findings that are backed directly by the underlying evidence, but it's worth keeping in mind when weighing findings that lean on sampled populations.